Fiche de défense pour le jury — Orbis Pay est une entreprise fictive. Vidéo de démo : lien à ajouter après le tournage.

La menace. Un contenu piégé vise deux lecteurs. Le salarié clique un lien trompeur, ouvre un site sosie ou valide un virement réclamé par un faux dirigeant. L'agent IA interne lit un mail qui cache une consigne, la prend pour une tâche et tente d'envoyer des données dehors avec ses propres droits. sAIfe suit les deux chemins jusqu'au même dossier SOC, où un humain décide. Hors sAIfe : 33,1 % des salariés non formés échouent aux tests de phishing simulés (KnowBe4 2025) ; EchoLeak, CVE-2025-32711, fuite par Microsoft 365 Copilot sans clic (The Hacker News) ; injection via le serveur MCP de GitHub, mai 2025 (Invariant Labs).

Les contrôles

- Poste : l'app Mac prévient avant le geste (mail frauduleux, site louche, fichier à risque) et l'extension Chrome avant un site sosie. Le salarié choisit ; le poste n'est jamais bloqué, sauf un virement ou un export de clients, qui attend un second regard. Quatre modules qu'on peut couper (mails, onglet actif, téléchargements, agents IA du poste) ; au SOC partent la catégorie, le domaine et le choix, jamais le contenu d'un fichier ni la valeur d'un secret. La copie désarmée d'un mail frauduleux part du serveur de messagerie, pas du poste.
- Garde-mail : chaque mail est jugé sûr, suspect ou frauduleux, avec une phrase par signal (sosie, lien menteur, pièce piégée, fraude au président, consigne cachée).
- Passerelle de l'agent : désarmeur des consignes cachées avant lecture, jeton limité à la tâche, canaris, et tout envoi hors d'Orbis Pay retenu avant exécution.
- Boîte noire scellée en SHA-256 : `/verification` dit à quelle étape un dossier a été modifié ; rapport d'une page pour le RSSI.
- Exports par l'API : incident au format ECS, règles Sigma, brouillon NIS2 à relire.

Comment l'humain garde la main

- Le salarié est prévenu avant d'agir, avec la raison, et choisit. « Annuler » envoie un événement : la SOC compte un piège évité, sans ouvrir de dossier.
- Geste critique : le relecteur IA (Haiku) accorde ou refuse en quelques secondes, à partir de faits structurés. Les règles refusent d'office un virement au-dessus de 10 000 €, un export de clients vers l'extérieur ou un geste dont le texte contient une consigne pour une IA ; panne ou délai de plus de 8 s, ce sont les règles qui tranchent. L'analyste garde « Accorder » et « Refuser », avec motif.
- Agent : « Laisser passer » se confirme toujours ; sur un incident critique, « Couper » aussi, avec un motif obligatoire et cinq secondes pour annuler. Motif et auteur sont scellés. Sans décision, l'appel retenu est refusé.
- Le salarié apparaît sous pseudonyme ; lever son identité demande un motif, et l'acte est scellé.
- Les règles du SOC s'écrivent en français ; sAIfe montre ce qu'il a compris et n'active rien sans confirmation.
- Seuils : session classée agent IA au-dessus de 0,40 ; canari touché ou envoi externe, l'agent est suspendu ; comportement inhabituel (pic d'appels, outil jamais vu, volume lu ×10), simple alerte ; pré-tri du relecteur sous 0,7 de confiance, file « à regarder ».

Ce qu'on a mesuré

Le 10 octobre 2026 à 22 h 10, commit `a1a7321`, sur des backends isolés (port libre, base temporaire). Trafic et mails écrits pour la démo.

- Agent interne piégé, vraie passerelle : 25/25 sessions classées agent IA, 25/25 incidents, 0 rapport sorti. Détection : médiane 10 ms, moyenne 11 ms. Confinement : médiane 19 ms, moyenne 20 ms, coupure envoyée par script. 25 échantillons chacun.
- Agent IA externe : 25/25 incidents. Faux positifs : 0/50 sessions humaines ou scriptées classées agent IA.
- 12 mails de démo : 8/8 frauduleux repérés, 0/3 légitime signalé, le douteux classé « suspect ». Désarmeur : consigne retirée dans 2/2 mails qui en portent une, 0/10 ailleurs.
- Relecteur IA, 6 gestes critiques : 6/6 tranchés par Haiku sans repli, 1 accordé, 5 refusés, médiane 3,3 s.

Non mesuré : le temps de décision d'un analyste humain, un vrai modèle dans l'agent, un vrai poste.

Tests

555 tests réussis le 10 octobre 2026 à 22 h 12, commit `a1a7321` : backend 195, interne 162, messagerie 73, attaque 29, poste 17, ancienne surface externe 19, scripts de démo 34, extension 26. Hors tests Swift de l'app Mac. Ils vérifient le prototype, pas une détection en production.

Limites

Trafic et mails écrits pour la démo, entreprise fictive : ces chiffres montrent la cohérence du moteur, pas une détection en production. Agent scripté, aucun vrai modèle mesuré dans l'agent. Désarmeur, analyseur de mails et extension reposent sur des motifs : une consigne paraphrasée et polie peut passer, d'où le contrôle de l'action. Le relecteur IA peut accorder à tort un geste que les règles laissent ouvert. Pas de branchement sur Outlook ou Gmail, pas d'annuaire d'identités. Prévu avant un déploiement : conservation de 90 jours, information des salariés et du CSE. SQLite et un seul écrivain. Brouillon NIS2 et correspondances jamais audités.

Correspondances (repères, pas une certification)

OWASP Agentic ASI01 (détournement d'objectif), ASI02 (usage abusif des outils), ASI03 (abus d'identité et de privilèges) ; MITRE ATLAS AML.T0051.001, T0053, T0057 ; ATT&CK T1566 phishing ; T1552, T1048, T1567, T1200 typés pour les gestes du poste, sans mesure ; NIST CSF 2.0 DE.CM-09, DE.AE-02, DE.AE-08, RS.MA-02, RS.AN-03, RS.MI-01 ; NIS2 art. 23 : sAIfe prépare le brouillon d'alerte sous 24 h, l'humain qualifie et notifie.

Cible, modèle, équipe

Entreprises régulées (finance sous DORA, santé), 500 à 5 000 salariés, avec un SOC et au moins un agent IA en production ou en pilote. Le RSSI achète, l'analyste SOC utilise, le DPO valide, le CSE est consulté pour le poste. Licence annuelle par agent supervisé, poste en option, pilote de 3 mois, pas de prix : hypothèses à tester en dix entretiens de RSSI, aucun client. Équipe : Guilhem (agents IA et technique), Paul (mails et business).